



NANYANG
TECHNOLOGICAL
UNIVERSITY
SINGAPORE

*Addressing Issues in Generative AI System
Design and Deployment*

Part 2-Chapter 4: Secure Deployment and Post-Deployment

Ong Chin Ann

Lecturer

College of Computing & Data Science
(chinann.ong@ntu.edu.sg)



COPYRIGHT STATEMENT

- All course materials, including but not limited to, lecture slides, handout and recordings, are for your own educational purposes only. **All the contents of the materials are protected by copyright, trademark or other forms of proprietary rights.**
- All rights, title and interest in the materials are owned by, licensed to or controlled by the University, unless otherwise expressly stated. **The materials shall not be uploaded, reproduced, distributed, republished or transmitted in any form or by any means, in whole or in part, without written approval from the University.**
- You are also not allowed to take any photograph, film, audio record or other means of capturing images or voice of any contents during lecture(s) and/or tutorial(s) and reproduce, distribute and/or transmit any form or by any means, in whole or in part, without the written permission from the University.
- Appropriate action(s) will be taken against you including but not limited to disciplinary proceeding and/or legal action if you are found to have committed any of the above or infringed the University's copyright.

Part 2-Topic 4: Secure Deployment and Post-Deployment

- What are the consideration when deploying AI systems?
- What other practices should the organization consider after deploying AI systems?

“ Deploying artificial intelligence (or GenAI) systems securely requires careful setup and configuration that depends on the complexity of the AI system, the resources required (e.g., funding, technical expertise), and the infrastructure used (i.e., on premises, cloud, or hybrid).”

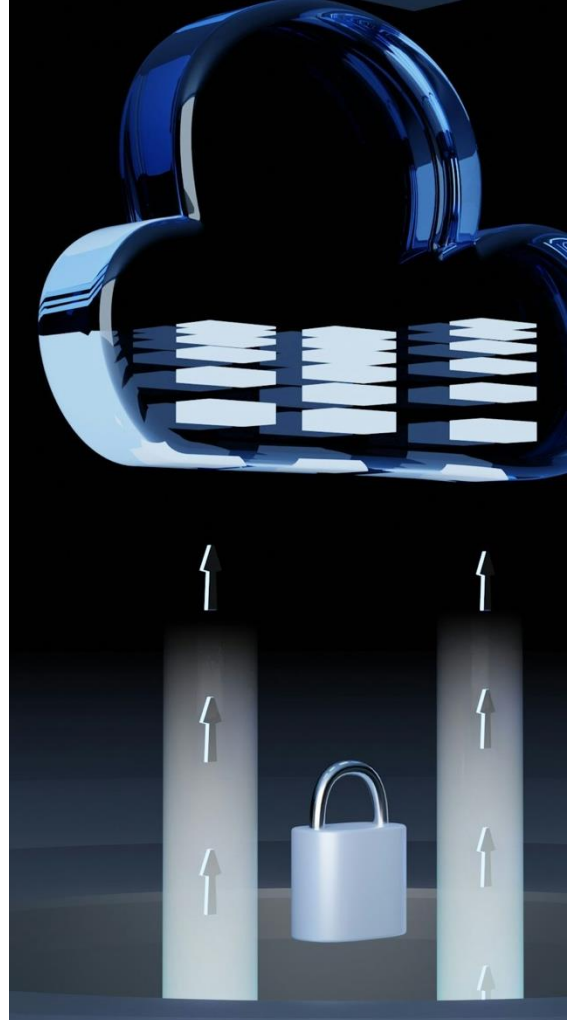
Deploying AI Systems Securely

Best Practices for Deploying Secure and Resilient AI Systems



Realtime Threats

- Malicious actors targeting AI systems may use attack vectors unique to AI systems, as well as standard techniques used against traditional IT.
- Due to the large variety of attack vectors, defenses need to be diverse and comprehensive.
- Advanced malicious actors often combine multiple vectors to execute operations that are more complex.
- Such combinations can more effectively penetrate layered defenses.
- Organizations should consider the following best practices to **secure the deployment environment**, continuously protect the AI system, and **securely operate, monitor, and maintain** the AI system.



Secure Deployment

NCSC Guidelines for Secure AI System Development

- Secure your infrastructure
- Protect your model continuously
- Develop incident management procedures
- Release AI responsibly
- Make it easy for users to do the right things

Secured Infrastructure

- apply good infrastructure security principles to the infrastructure used in every part of your system's life cycle.
- You apply appropriate access controls to your APIs, models and data, and to their training and processing pipelines, in research and development as well as deployment.
 - For example, segregation of environments holding sensitive code or data.
- These steps help mitigate standard cyber security attacks which aim to steal a model or harm its performance.



Secured Infrastructure

- Manage deployment environment governance
 - Identify the deployment environment's security boundaries and how the AI system fits within them.
 - leverage the threat model as a guide to implement security best practices, assess potential threats, and plan mitigations.
 - Identify the roles and responsibilities for each stakeholder along with how they are accountable for fulfilling them
- Ensure a robust deployment environment architecture
 - Identify and address blind spots in boundary protections and other security-relevant areas in the AI system the threat model identifies. i.e. implement access control.
 - Apply secure by design principles and [Zero Trust \(ZT\) frameworks](#) to the architecture to manage risks to and from the AI system.



Secured Infrastructure

- Harden deployment environment configurations
 - Apply existing security best practices to the deployment environment. i.e. sandboxing (container / VMs), monitoring network, and firewalls.
 - Review hardware vendor guidance and notifications and apply software patches and updates to minimize the risk of exploitation of vulnerabilities
 - Secure sensitive AI information, encrypting the data at rest, and store encryption keys in a hardware security module.
 - Implement strong authentication mechanisms, access controls, and secure communication protocols.
 - Ensure the use of phishing-resistant multifactor authentication (MFA) for access to information and services



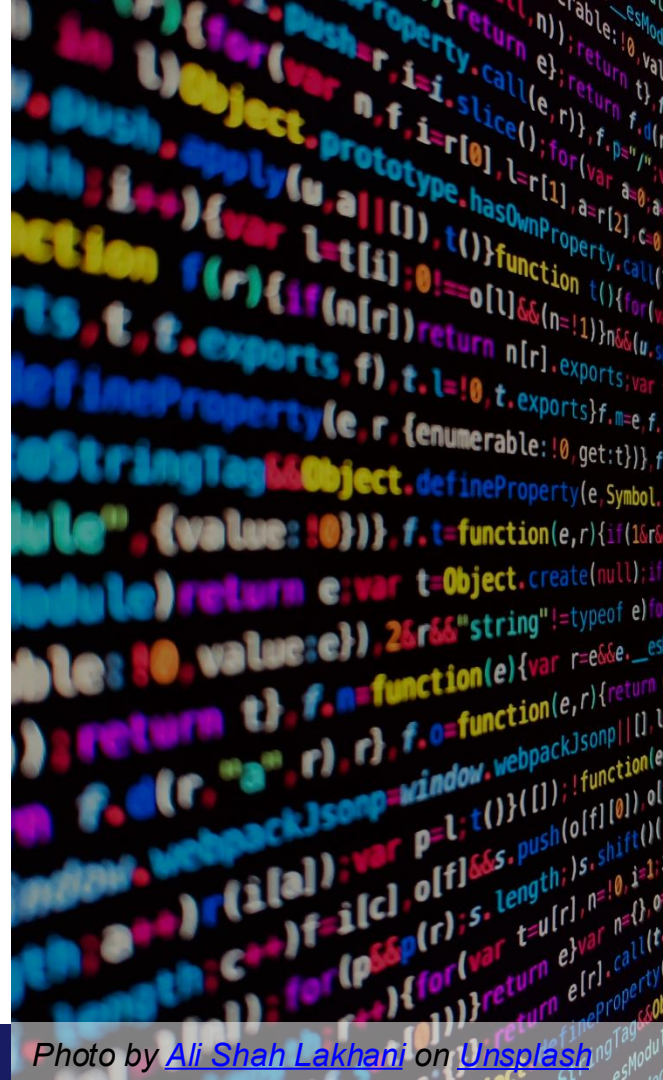
Secured Infrastructure

- Protect deployment networks from threats
 - Adopt a ZT mindset, which assumes a breach is inevitable or has already occurred.
 - Implement detection and response capabilities, enabling quick identification and containment of compromises.
 - i.e. immediately block access by users suspected of being malicious or to disconnect all inbound connections to the AI models and systems in case of a major incident



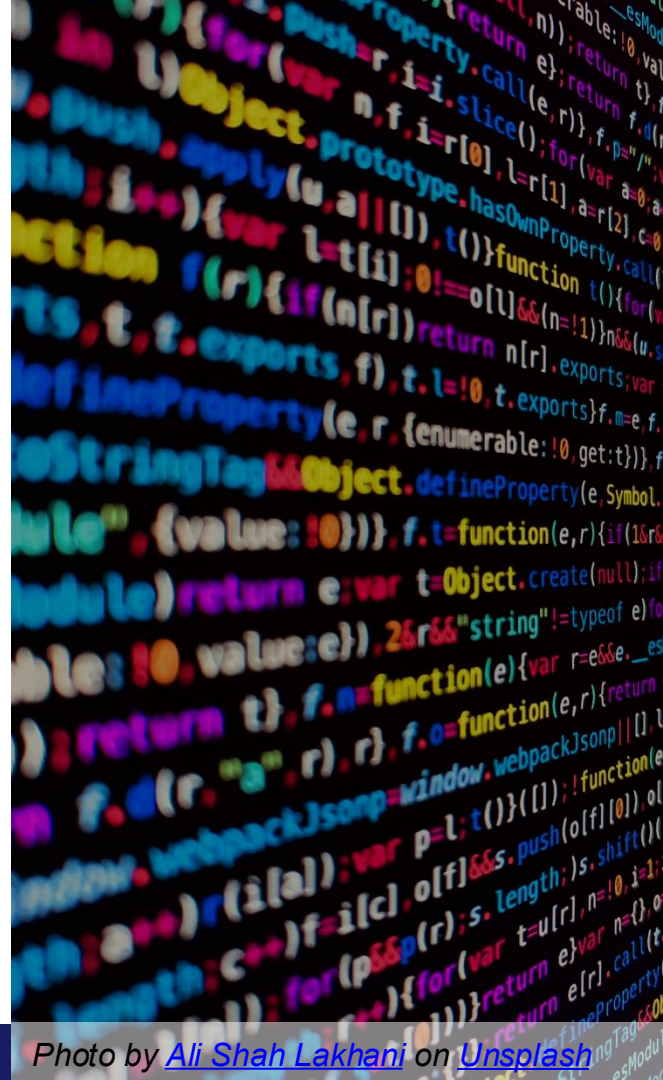
Secured Model

- Attackers may be able to reconstruct the functionality of a model or the data it was trained on.
 - Via direct (acquire model weights) or indirect access (API)
- Attackers may also tamper with models, data or prompts during or after training, rendering the output untrustworthy.



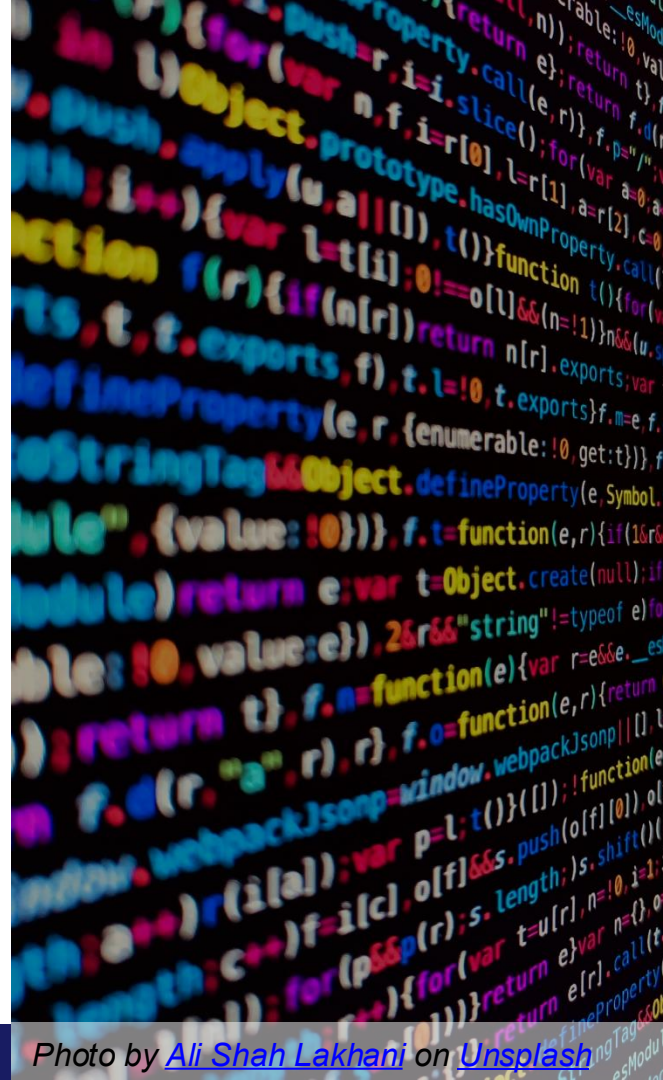
Secured Model – Best Practices

- implementing controls on the query interface to detect and prevent attempts to access, modify, and exfiltrate confidential information.
- **Model Validation**: compute and share cryptographic hashes and/or signatures of model files (for example, model weights) and datasets.
- **Key Management** is essential
- Apply **privacy-enhancing technologies** to explore or assure levels of risk associated with consumers, users and attackers having access to models and outputs.



Secured Model – Techniques

- Validate the AI system before and during use
 - Use cryptographic methods, digital signatures, and checksums to confirm each artifact's origin and integrity
 - Create hashes and encrypted copies of each release of the AI model and system for archival in a tamper-proof location
 - Store all forms of code and artifacts in a version control system with proper access controls
 - Evaluate and secure the supply chain for any external AI models and data, making sure they adhere to organizational standards and risk management policies, and preferring ones developed according to secure by design principles.
 - Prepare for automated rollbacks and use advanced deployments with a human-in-the-loop as a failsafe to boost reliability, efficiency, and enable continuous delivery for AI systems.



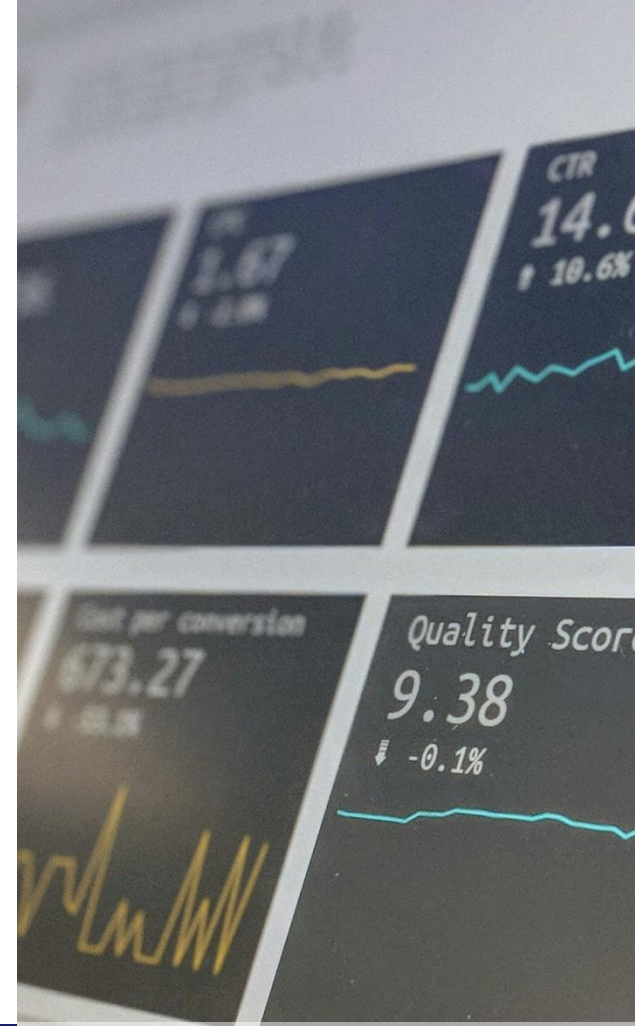
Secured Model – Techniques

- Secure exposed APIs
 - implement authentication and authorization mechanisms for API access.
- Protect model weights
 - Harden interfaces for accessing model weights to increase the effort it would take for an adversary to exfiltrate the weights. i.e. model only return minimal data as needed.
 - Aggressively isolate weight storage



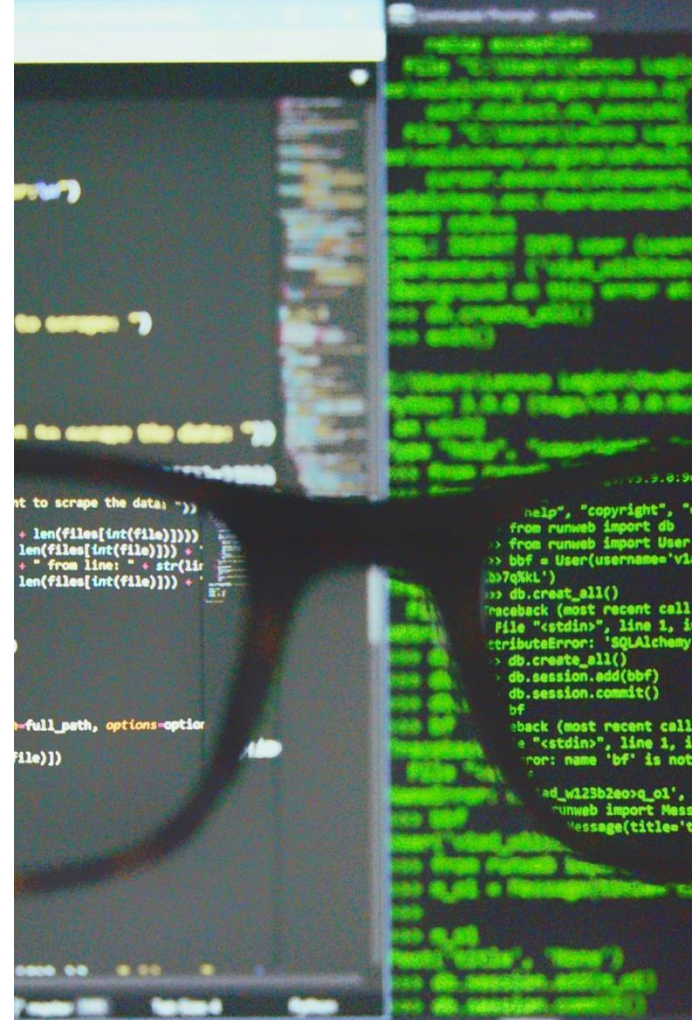
Incident Management Procedure

- The inevitability of security incidents affecting your AI systems is reflected in your incident response, escalation and remediation plans.
- Regularly reassessed incident management plan as the system and wider research evolves.
- Store and manage critical company digital resources in offline backups.
- Train incident respondent team.
- provide high-quality audit logs and other security features or information to customers and users at no extra charge.
 - Will helps in their incident responses processes.



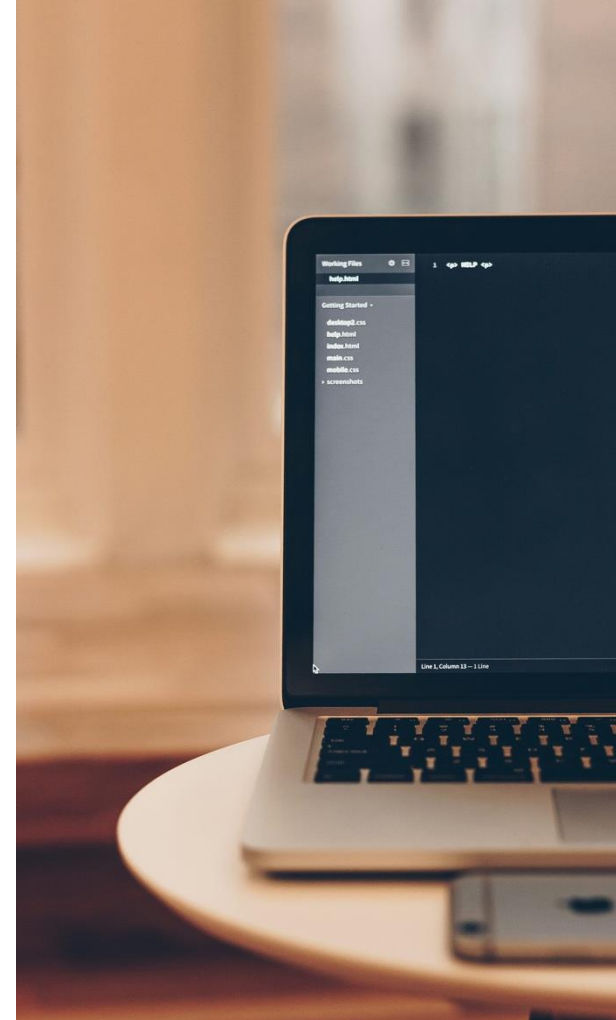
Release AI Responsibly

- Conduct appropriate and effective security evaluation such as benchmarking and [red teaming](#).
 - GenAI Red Teaming provides a structured approach to identify vulnerabilities and mitigate risks across AI systems focusing on security, and trust.
 - Including other tests that are out of scope for these guidelines, such as safety or fairness.
- Conduct audits and penetration testing
 - Engage external security experts to conduct audits and penetration testing on ready-to-deploy AI systems.
 - This helps identify vulnerabilities and weaknesses that may have been overlooked internally.
- Be clear to your users about known limitations or potential failure modes.



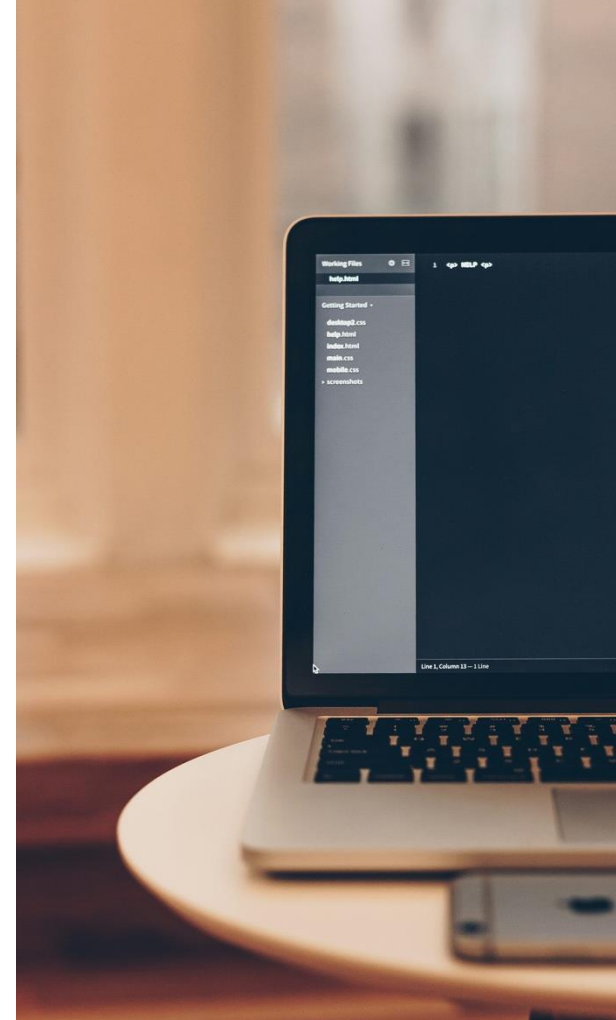
Usability Enhancement

- Make it easy for users to do the right things
- each new setting or configuration option is to be assessed in conjunction with the business benefit it derives, and any security risks it introduces.
- **Secure by Default** - the most secure setting will be integrated into the system as the only option.
 - When configuration is necessary, the default option should be broadly secure against common threats.
- Apply controls to prevent the use or deployment of your system in malicious ways.



Usability Enhancement (Cont.)

- provide users with guidance on the appropriate use of your model or system
 - highlighting limitations and potential failure modes.
- State clearly to users which aspects of security they are responsible for.
- Being transparent about where (and how) their data might be used, accessed or stored.
 - for example, if it is used for model retraining, or reviewed by employees or partners.



Ensure user awareness and training

- Educate users, administrators, and developers about security best practices, such as strong password management, phishing prevention, and secure data handling.
- Promote a security-aware culture to minimize the risk of human error.
- If possible, use a credential management system (i.e. SSO) to limit, manage, and monitor credential use to minimize risks further



Secure Operation and Maintenance

NCSC Guidelines for Secure AI System Development

- Monitor system's behaviour
- Monitor system's input
- Follow a secure by design approach to updates
- Collect and share lesson learned

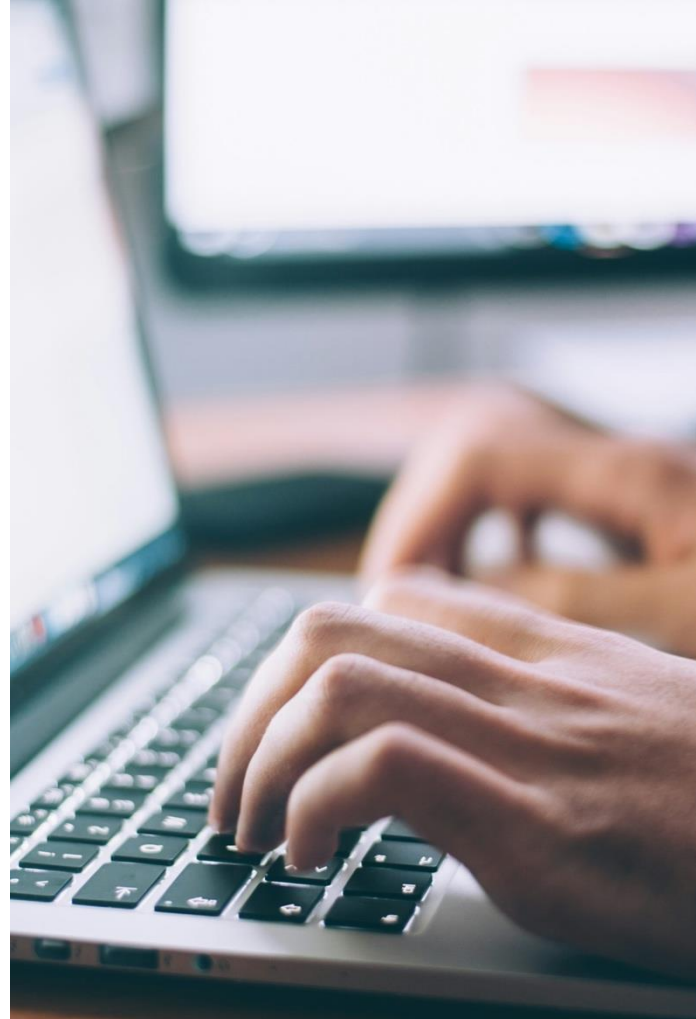
Monitor System's Behaviour

- Measure the outputs and performance of the model and system
 - observe sudden and gradual changes in behaviour affecting security.
- Detect for and identify potential intrusions and compromises, as well as natural data drift (hallucination)



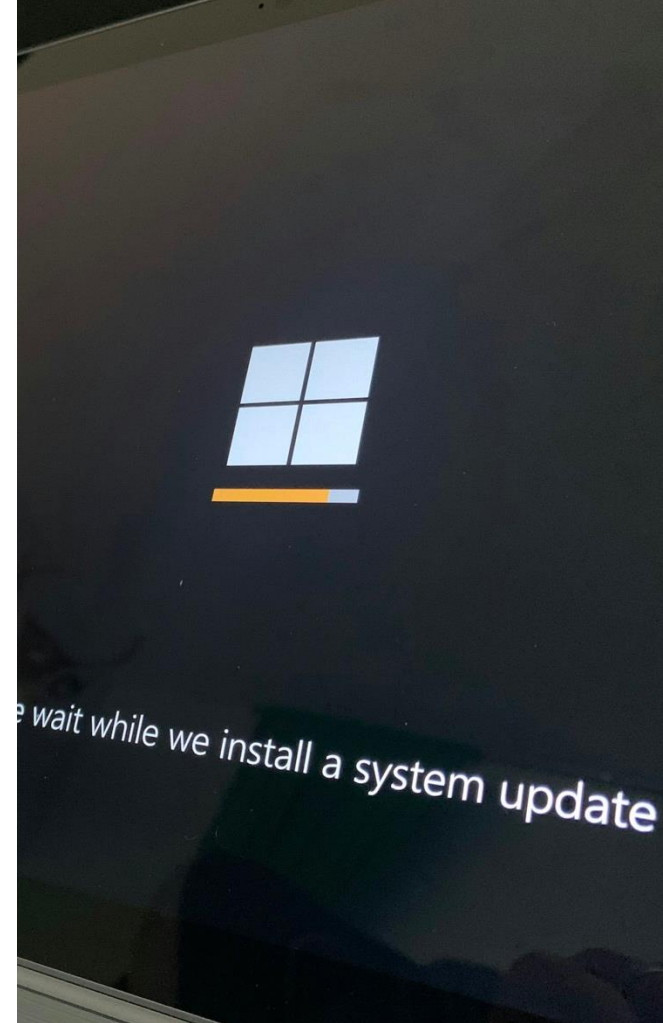
Monitor System's Input

- Monitor and log inputs to your system (such as inference requests, queries or prompts)
 - Enable compliance obligations, audit, investigation and remediation in the case of compromise or misuse.
 - In line with privacy and data protection requirements
- include explicit detection of out-of-distribution and/or adversarial inputs
 - detect those that aim to exploit data preparation steps (such as cropping and resizing for images).
- Watch for data drift or high frequency or repetitive inputs
 - these could be signs of model compromise or automated compromise attempts.



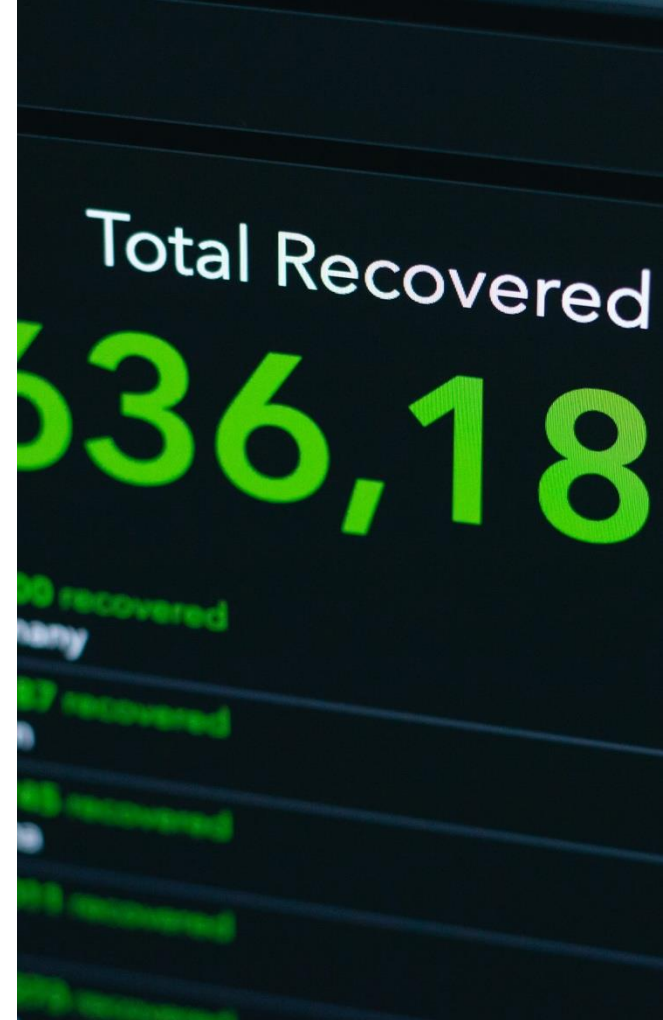
Secure Updates

- Follow a **secure by design** approach to updates
- include **automated updates by default** in every product and use secure, modular update procedures to distribute them.
- update processes (including testing and evaluation regimes) reflect the fact that changes to data, models or prompts can lead to changes in system behaviour
 - for example, you treat major updates like new versions
- support users to evaluate and respond to model changes
 - for example by providing preview access and versioned APIs



Reliability, Recovery, and House Keeping

- Prepare for high availability (HA) and disaster recovery (DR)
 - Use an immutable backup storage system,
 - to ensure that every object, especially log data, is immutable and cannot be changed
- Plan secure delete capabilities
 - Perform autonomous and irretrievable deletion of components,
 - For example, training and validation models or cryptographic keys, without any retention or remnants at the completion of any process where data and models are exposed or accessible.



Collect and share lessons learned

- Participate in information-sharing communities, collaborating across the global ecosystem of industry, academia and governments to share best practice as appropriate.
- maintain open lines of communication for feedback regarding system security, both internally and externally to your organisation.
 - including providing consent to security researchers to research and report vulnerabilities
- escalate issues to the wider community,
 - for example publishing bulletins responding to vulnerability disclosures, including detailed and complete common vulnerability enumeration.
- take action to mitigate and remediate issues quickly and appropriately



Summary

- Deploying artificial intelligence (or GenAI) systems securely requires careful setup and configuration.
- Advanced malicious actors often combine multiple vectors to execute operations that are more complex.
- defenses need to be diverse and comprehensive.
- To ensure secure deployment, software manufacturer must choose the deployment infrastructure which is secure to protect the code and model, as well as to ensure it is easy for the user to do the right thing.
- The software manufacturer should also incorporate active and continuously monitor the system behavior and user input for arbitrary and malicious pattern.
- Finally, the software manufacturer are encouraged to collect and share lesson learned.

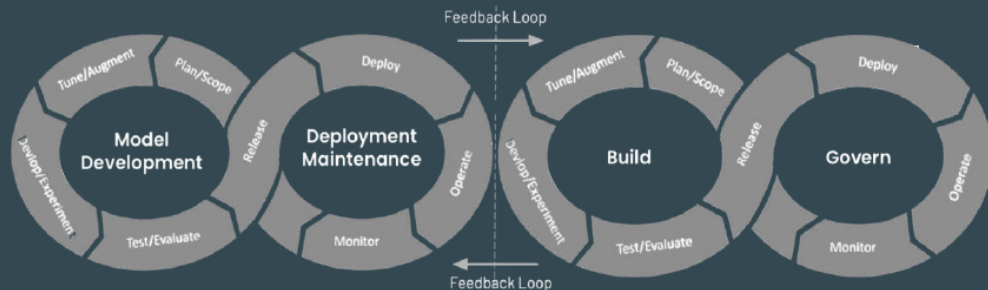
Putting All Together...

**SECURE DESIGN, DEVELOPMENT, DEPLOYMENT,
OPERATION, AND MAINTENANCE**



CHEAT SHEET

LLM and Gen AI App SecOps Framework



The OWASP LLMSecOps Framework was captured to help better align LLMops processes and the security roles and dependencies for each stage. While LLMops and MLOps are rooted in the same foundational principles of lifecycle management, they can diverge significantly in their focus and requirements, as one is focused primarily on model development, while the other extends DevOps to include support for various LLM, Gen AI and application patterns.

Plan & Scope

- Access Control and Authentication Planning
- Compliance and Regulatory Assessment
- Data Privacy and Protection Strategy
- Early Identification of Sensitive Data
- Third-Party Risk Assessment (Model, Provider, etc.)
- Threat Modeling

Augment & Fine Tune Data

- Data Source Validation
- Secure Data Handling
- Secure Output Handling
- Adversarial Robustness Testing
- Model Integrity Validation (ex: serialization scanning for malware)
- Vulnerability Assessment

Dev & Experiment

- Access, Authentication, and Authorization (MFA)
- Experiment Tracking
- LLM & App Vuln Scanning
- Model and Application Interaction Security
- SAST/DAST
- Secure Coding Practices
- Secure Library/Code Repository
- Software Comp Analysis

Test & Evaluation

- Adversarial Testing
- Application Security Orchestration and Correlation
- Bias and Fairness Testing
- Final Security Audit
- Incident Simulation, Response Testing
- LLM Benchmarking
- Penetration Testing
- IAST
- Vulnerability Scanning

Release

- AI/ML Bill of Materials (BOM)
- Digital Model/Dataset Signing
- Model Security Posture Evaluation
- Secure CI/CD pipeline
- Secure Supply Chain Verification
- Static and Dynamic Code Analysis
- User Access Control
- Validation
- Model Serialization Defenses

Deploy

- Compliance Verification
- Deployment Validation
- Digital Model/Dataset Verification
- Encryption, Secrets management
- Multi-factor Authentication
- Network Security Validation
- Secure API Access
- Secure Configuration
- User and Data Privacy Protections

Operate

- Adversarial Attack Protection
- Automated Vuln Scanning
- Data Integrity and Encryption
- LLM Guardrails
- LLM Incident Detection and Response
- Patch Management
- Privacy, Data Leakage Protection
- Prompt Security
- Runtime Self-Protection
- Secure Output Handling

Monitor

- Adversarial Input Detection
- Model Behavior Analysis
- AI/LLM Secure Posture Management
- Patch and Update Alerts
- Regulatory Compliance Tracking
- Security Alerting
- Security Metrics Collection
- User Activity Monitoring
- Observability
- Data Privacy and Protection
- Ethical Compliance

Govern

- Bias and Fairness Oversight
- Compliance Management
- Data Security Posture Management
- Incident Governance
- Risk Assessment and Management
- User/Machine Access audits

References

- NCSC Guidelines for Secure AI System Development
- Joint Guidance on Deploying AI Systems Securely:

<https://www.cisa.gov/news-events/alerts/2024/04/15/joint-guidance-deploying-ai-systems-securely>

Guidelines for secure AI system development

